# Análisis del diseño seguro de autenticación y autorización en Saleor

*Segundo avance del proyecto CyberMarket CR*

Equipo CyberMarket CR

Universidad Fidélitas · CY-703 Seguridad de Software

Preparado el 2 de noviembre de 2026

## Resumen

Se evalúan controles de autenticación, tokens y autorización de seis operaciones GraphQL del fork Arkthos/saleor para el escenario ficticio CyberMarket CR. El estudio combina revisión de código, requisitos ASVS 5.0.0, procedimientos WSTG 4.2, análisis estático y pruebas reproducibles. Se verificaron los archivos originales de la ejecución integrada histórica, con 59 pruebas focales aprobadas y dos fallos esperados de una política provisional. Se añadieron diez unidades con 30 variantes aprobadas y doce invocaciones aprobadas de validadores de evidencia. Bandit produjo una alerta revisada como falso positivo; Semgrep no encontró coincidencias con cinco reglas locales. Se presentan catorce hallazgos con recomendaciones. Los resultados permiten describir controles y brechas de decisión, sin establecer seguridad global ni explotación real. La revalidación integrada nueva y el despliegue con navegador permanecen fuera de la evidencia obtenida.

Palabras clave: autenticación, autorización, GraphQL, pruebas de seguridad, desarrollo seguro.

## I Continuidad del proyecto y alcance

La segunda entrega documenta las fases de desarrollo y pruebas mediante tres apartados exigidos por la consigna: codificación segura, análisis estático y dinámico, y pruebas de seguridad. El requisito adicional de al menos diez hallazgos con recomendaciones se atiende con un catálogo de catorce observaciones técnicas diferenciadas [1]. El propósito es explicar qué se examinó, cómo se obtuvo cada resultado y qué decisiones permite, sin identificar la cantidad de tests con la calidad o la seguridad del producto.

El primer avance estableció el problema, la arquitectura conceptual, los actores, trece escenarios de riesgo y quince observaciones estáticas. También delimitó las operaciones tokenCreate, tokenRefresh, tokensDeactivateAll, me, user y order [2]. Esa delimitación se conserva. El código base se distribuye bajo BSD-3-Clause; se verificó LICENSE en el commit de referencia [3]. La autorización del usuario para trabajar en su fork y los datos sintéticos delimitan la actividad realizada. No se realizaron pruebas sobre servicios de terceros. CyberMarket CR es un contexto empresarial ficticio; Saleor y el fork investigado son artefactos reales. No se atribuyen incidentes, clientes, pérdidas o aprobaciones de una empresa existente al escenario académico.

El objetivo general se mantiene: evaluar los mecanismos de autenticación, gestión de tokens y autorización en seis operaciones seleccionadas de la API GraphQL de un fork versionado de Saleor, mediante requisitos de seguridad trazables, revisión técnica y procedimientos de verificación controlados, para identificar riesgos y formular recomendaciones fundamentadas en evidencia para el escenario ficticio CyberMarket CR. Sus tres objetivos específicos se desarrollan mediante la caracterización de arquitectura y amenazas, el examen técnico de controles y la documentación de al menos diez observaciones con recomendaciones y verificación de mitigaciones técnicamente viables. El informe responde a esos objetivos con productos y límites localizables, sin reformularlos para acomodar los resultados.

Según lo comunicado por el grupo, no se han recibido correcciones del profesor. Los ajustes de esta entrega corresponden a la continuidad de la investigación: actualizar el estado experimental, precisar los instrumentos aplicados, clasificar pruebas y contrastar resultados con criterios explícitos. El Word presentado se conserva; esta entrega es una versión nueva. Su estilo de citación es IEEE, admitido por la consigna. El programa y el manual aportan el marco de metodología y discusión de resultados [4].

El ciclo de vida se emplea como relación entre decisiones de requisitos, implementación, verificación y tratamiento. SSDF 1.1 propone integrar prácticas de desarrollo seguro en los modelos de ciclo de vida [5]. En este caso, ese referente organiza la relación entre productos y evidencia; el estudio no pretende evaluar exhaustivamente todas sus prácticas ni certificar la madurez de un proceso empresarial.

## II Metodología y condiciones de evaluación

### A Diseño y unidades de análisis

Se realizó una evaluación técnica controlada, descriptiva y evaluativa de artefactos de software. La muestra es intencional: seis operaciones de identidad y acceso, más los componentes que intervienen directamente en su validación. Las utilidades de IP, ofuscación o comparación de tokens se incorporan por esa dependencia, sin convertir el estudio en una auditoría de todos los módulos comerciales de Saleor.

La relación amenaza, requisito, comprobación y evidencia se construyó mediante una adaptación documental de actividades de ingeniería de requisitos. SQUARE aporta pasos para acordar definiciones y metas, elaborar artefactos, evaluar riesgos y obtener requisitos [6]. No se declara ejecución íntegra de su proceso ni entrevistas con stakeholders reales. Las decisiones del caso ficticio deben permanecer identificadas como supuestos o propuestas hasta que el grupo adopte un criterio concreto.

ASVS 5.0.0 define los requisitos usados como referencia [7]. WSTG 4.2 orienta procedimientos que se adaptaron a las

operaciones GraphQL seleccionadas [8]. La adaptación no crea equivalencias oficiales entre sus IDs: una prueba puede aportar solo parte de la evidencia necesaria para un requisito y un mismo requisito puede necesitar análisis documental, inspección de código y varias ejecuciones.

### B Versiones y configuración

El producto base es Arkthos/saleor en 4cb1609a90eade14b6275a407bc7a00c35698090 [3]. Al iniciar la preparación de esta entrega, la rama de investigación tenía HEAD 6af5fbad0101d3261055b2bcb089df3255fc1053. Su comparación con la base mostró 49 archivos distintos relacionados con pruebas, herramientas de evidencia, workflow e instrucciones o documentación; no había cambios en el código funcional del producto. Los commits documentales posteriores y los tests nuevos se identifican por separado en los manifiestos.

La ejecución integrada histórica de referencia corresponde al run 39443927080, branch SHA c442099bc0ebee5194a6e58354944563e92e0d28 y checkout de integración b0604014dab69125a4a535f1ece5828be99ea3c8 [9]. Su log registra CPython 3.12.15, Django 5.2.17, Graphene 2.1.9, graphql-core 2.3.2, PyJWT 2.14.0 y pytest 9.0.3, con PostgreSQL 15-alpine y Valkey 8.1-alpine. Se conservaron los digests observados de imágenes; las etiquetas de un workflow no garantizan por sí solas que una ejecución posterior use los mismos bytes.

La nueva ejecución local utilizó Python 3.12.14 y dependencias instaladas desde el mismo uv.lock. La compilación de pywatchman falló inicialmente por ausencia de clang y se completó con CC=gcc, sin cambiar el lockfile. Los tests de producto nuevos quedaron publicados en 5c7e4233ba24412ed80e3cd9a76a2ee18e4990a9 [10]. El manifiesto registra también su hash de archivo y el checkout local base, de modo que un commit documental no se confunda con el contenido efectivamente probado.

Las settings de pruebas usan correo en memoria, tareas Celery eager y un hasher de pruebas. Estas condiciones reducen dependencias del laboratorio y no representan el coste o la configuración de producción. La capa aislada se ejecutó sin conftest.py global, con un worker, sin DB o caché remotas y con una clave sintética de longitud suficiente para los casos criptográficos. Esa decisión se explica porque las fixtures globales intentaban inicializar PostgreSQL incluso al ejecutar validadores que no lo necesitan.

### C Instrumentos y recolección

Los instrumentos I01–I07 del primer avance conservan su función. I01 registra configuración, versiones y hashes; I02 describe componentes y fronteras; I03 mantiene riesgos; I04 relaciona requisitos; I05 conserva casos y resultados; I06 documenta observaciones y recomendaciones; I07 mantiene la cadena de evidencia y cita. La correspondencia aplicada se presenta en el anexo A. Los instrumentos son registros de unidades técnicas, no encuestas o mediciones sobre una población humana.

Se recogieron rutas y rangos de código, resultados de herramientas, JUnit, JSON de casos, configuración no sensible y manifiestos de archivos. Los ZIP históricos se descargaron y su SHA-256 se comparó con los digests informados por GitHub. Se comprobaron los SHA256SUMS internos disponibles y se analizaron de forma independiente los XML. Esto permite distinguir la lectura de un informe previo de la verificación de sus archivos fuente.

La interpretación separa contrato local, caracterización, requisito de referencia y política propuesta. PASS significa que una aserción se cumplió bajo sus precondiciones. En una caracterización puede confirmar un comportamiento que todavía requiera una decisión de seguridad. XFAIL señala que una expectativa marcada como pendiente sigue sin cumplirse; no significa corrección ni conformidad. ERROR, SKIP y ausencia de ejecución se conservan como tales.

## III Codificación segura

### A Mediación y responsabilidades

Los principios de privilegios mínimos y mediación completa ayudan a examinar dónde se decide el acceso [11]. La presencia de una función de autenticación no basta para describir la autorización: debe seguirse la credencial hasta la operación, el objeto y el campo que se devuelve. En el código revisado, la extracción de cabeceras, la gestión JWT, las mutaciones y los resolvers tienen responsabilidades diferenciadas. Esa separación facilita inspección y pruebas, aunque no demuestra cumplimiento general de SOLID.

La cadena de autenticación ofrece un ejemplo de por qué importa el contexto. is_saleor_token decodifica sin verificar firma para clasificar el propietario del token. load_user_ from_request llama después a jwt_decode y comprueba tipo, usuario y clave por usuario antes de aceptar la identidad. Reportar aceptación de tokens sin firma a partir de la primera llamada aislada omitiría el control posterior. La revisión se apoyó en la cadena y en pruebas negativas concretas, no en la mera aparición de una opción con nombre sensible.

BaseMutation.mutate consulta check_permissions antes de perform_mutation. La implementación base permite continuar si no hay permisos declarados, como punto de extensión. H10 del primer avance identifica ese comportamiento, pero su evaluación requiere revisar Meta.permissions, sobreescrituras y validaciones de cada operación. La recomendación es hacer explícitos los contratos de acceso y sus excepciones; no etiquetar automáticamente como vulnerabilidad toda mutación sin permisos en su metaclase.

### B Validación de datos y estados

RefreshToken distingue el propósito de la credencial y el transporte por argumento o cookie. La ruta de cookie exige CSRF; la de argumento tiene otro contrato. Esto vincula las precondiciones del cliente con la decisión de seguridad. Las pruebas deben cubrir cada rama y evitar extrapolar el resultado de un mecanismo a validaciones de origen o almacenamiento que no se observaron.

La emisión de access y refresh incluye tiempos configurables. Su presencia permite comprobar el TTL emitido, pero una sesión puede abarcar varias renovaciones. Por ello se separan autenticidad de firma, vigencia del token, tipo, audiencia, revocación y política temporal de sesión. Cada propiedad necesita su propio criterio. Las unidades nuevas amplían firma alterada, exp y nbf; no sustituyen una decisión sobre reautenticación o vida absoluta.

En datos de pedidos, el código diferencia identificadores UUID nuevos y números legacy. Los resolvers de direcciones y correo participan en el resultado final y pueden devolver campos originales o transformados según esa ruta. El diseño de pruebas incluye actor, identificador y campo para no interpretar la obtención del objeto como equivalente a la divulgación de todos sus atributos.

### C Errores y robustez

get_payload traduce excepciones JWT específicas a errores de la API. Esto permite mantener una respuesta controlada ante firma o vigencia inválidas. En get_user, en cambio, un catch de Exception convierte causas diversas en ausencia de usuario. La inspección sostiene una observación de diagnósticos y robustez: una dependencia averiada podría quedar menos distinguible de una credencial inválida. No se demostró explotación de esa captura.

El helper de ofuscación de correo presupone un formato que se puede dividir en dos partes por arroba. Una unidad con varias arrobas reproduce ValueError. Ese resultado corresponde al helper y no prueba que una API admita esa entrada sin validación. La recomendación es comprobar sus consumidores, declarar la precondición y probar la validación del dato en el punto donde se produce.

### D Configuración e interfaces

El middleware de refresh establece HttpOnly y condiciona Secure/SameSite a DEBUG. La configuración forma parte de la propiedad de seguridad; leer el valor por defecto no identifica el despliegue efectivo. También se observa un nombre de cookie sin los prefijos examinados en ASVS 3.3.1. La aplicación de ese criterio requiere documentar finalidad de la cookie, contrato de cliente y canales de entrega del mismo valor, además del contexto HTTPS.

La IP usada para limitar intentos puede proceder de X-Forwarded-For. Validar que una cadena sea IPv4 o IPv6 no prueba que un emisor confiable la haya establecido. La arquitectura del proxy y la caché determinan parte del comportamiento operativo. Las pruebas unitarias de selección de IP y backoff documentan reglas de cálculo, mientras la validación del borde queda pendiente de un entorno desplegado.

## IV Análisis estático y dinámico

### A Revisión estática

Se registraron trece puntos de inspección manual en las dimensiones de control, datos, fallas e interfaces, en correspondencia con los contenidos docentes [12]. La revisión sigue rutas y decisiones concretas y complementa las herramientas. Sus localizadores y recomendaciones están en revision_manual.csv, junto con las relaciones a las observaciones iniciales.

Bandit 1.8.6 examinó 4629 líneas de las rutas sensibles seleccionadas con severidad mínima LOW y confianza mínima MEDIUM. Produjo una alerta B105 LOW/ MEDIUM sobre el literal refreshToken en saleor/core/ jwt.py:23. La inspección determinó que el literal es el nombre de una cookie y no una contraseña embebida. Se conserva el resultado y se clasifica como falso positivo respecto a esa regla. Esta decisión no resuelve la cuestión diferente de nomenclatura o configuración de cookies.

Semgrep 1.153.0 ejecutó cinco reglas Python locales en 21 archivos y produjo cero hallazgos y cero errores. El alcance queda limitado a esas reglas y rutas. No se efectuó SCA ni se extrajeron conclusiones sobre CVE o seguridad de todas las dependencias. Tampoco se utilizó una salida exitosa de herramienta como sustituto de la interpretación de permisos y políticas.

### B Dinámica e inventario histórico

Los casos GraphQL históricos son dinámicos porque ejecutan el programa. Su nivel es de integración cuando combinan esquema, fixtures y base de datos. Cuatro IDs también ejercitan directamente funciones pequeñas, pero la ejecución completa bajo fixtures globales no queda aislada por ese hecho. La clasificación distingue nivel, conocimiento del código, dependencias y alcance de aserción. El anexo B permite localizar los 27 IDs sin confundirlos con 61 controles diferentes.

La evidencia focal verificada contiene 61 variantes: 26 PASS de contratos locales, 33 PASS de caracterización y dos XFAIL de política propuesta. El XML tiene cero failures y errors. La suite general contiene 17 615 casos, con 17 613 PASS y los mismos dos XFAIL. La focal está incluida en la general; sumarlas produciría un conteo engañoso. La aprobación de una caracterización tampoco transforma la política propuesta de pedidos en un requisito oficial.

### C Ejecución nueva

Las diez unidades CM-U01–U10 produjeron 30 variantes aprobadas. Se separaron de doce invocaciones aprobadas de dos módulos del validador de evidencia. La corrida final de 42 ejecuciones no tuvo fallos, errores, omisiones o warnings. Los módulos de validación pueden comprobar condiciones solapadas y no se presentan como doce controles nuevos del producto. Ruff verificó reglas y formato del archivo añadido.

El primer intento de los seis tests del validador bajo las fixtures normales produjo seis errores de setup por ausencia de PostgreSQL. Esa evidencia se conservó y motivó el aislamiento de la capa que no necesita DB. Una corrida inicial de unidades aprobó 30 variantes, pero advirtió sobre la clave corta de las settings de prueba. El setup de los tests se cambió a una clave sintética larga y se repitió la ejecución. Se corrigió también la precisión del match de una excepción exigida por Ruff. Estas son mejoras del harness, sin una mitigación funcional atribuida a Saleor.

### D Límites operativos

La nueva revalidación integrada GraphQL, general y E2E no se ejecutó sobre el HEAD nuevo. Las consultas de Actions no devolvieron runs asociados a los commits examinados. El entorno local no dispone de Docker ni PostgreSQL activo y no permite cambiar de usuario para preparar un servidor PostgreSQL nativo. No se conectó a una base externa ni se sustituyó silenciosamente el motor por otro.

C10 conserva sus siete casos NOT_EXECUTED. La consigna admite análisis dinámico mediante las técnicas pertinentes y no obliga a desplegar públicamente el software. La exclusión deja sin verificar transporte HTTP real, navegador, TLS, proxy y flujo de entrega de UUID. Esas propiedades permanecen fuera de las conclusiones. El plan de laboratorio aislado sigue siendo una propuesta de continuidad y no una instalación realizada.

## V Pruebas de seguridad y detalle de casos

### A Diseño de controles

La muestra combina controles positivos, negativos y caracterización. CM-T02 establece una credencial válida antes de revocarla y reutilizarla; ese control permite atribuir la diferencia al cambio de estado. CM-T23 contrasta actores ajenos y anónimos por campo, CM-T24 conserva el control positivo del propietario y CM-T26 utiliza un identificador inexistente. Esta combinación reduce el riesgo de interpretar una fixture incorrecta o un dato ausente como protección del recurso.

Las unidades de firma también establecen un JWT válido antes de alterar su firma. Se cambia el primer carácter del segmento de firma, de forma que el cambio afecte bytes significativos. Los tests de exp y nbf fijan el reloj y crean tokens firmados con condiciones temporales distintas. Así se separa la causa del rechazo del mero hecho de que un token sea inválido por varias razones.

Para CSRF se producen máscaras válidas de secretos iguales o distintos y se compara la identidad del secreto. Los tests de ofuscación usan resultados literales: por ejemplo, una cadena de cuatro caracteres conserva el primero y sustituye tres, y un correo conserva su dominio. La expectativa no llama al mismo helper bajo prueba. Esto amplía la evidencia histórica, que comparaba algunas salidas con las funciones de implementación.

### B Ejemplo de ficha de revocación

El caso CM-T02 usa un cliente sintético autenticado y una cuenta de fixture. Sus precondiciones incluyen access y refresh emitidos antes de la operación y una consulta me que devuelve la identidad esperada. La acción es tokensDeactivateAll. El resultado esperado exige que la revocación no produzca errores, que el access previo no recupere datos de me y que el refresh previo no emita un token nuevo.

El resultado histórico cumple esas aserciones: la consulta posterior carece de datos de identidad y expone el error de token inválido, mientras la renovación devuelve token nulo y el código esperado. La conclusión es una invalidación observada de ambos tipos en esas rutas. La ficha no cubre todos los consumidores, cachés o proveedores externos. Su recomendación es conservar la regresión y ampliar el inventario cuando entre un consumidor nuevo.

### C Ejemplo de ficha de pedidos

CM-T23 usa un pedido UUID conocido, actor ajeno o anónimo y uno de tres campos sintéticos: correo, calle de facturación o calle de envío. Comprueba las precondiciones de propiedad y tipo de identificador. El valor esperado de caracterización coincide con el valor de la fixture. Seis variantes aprobadas muestran campos originales para esos dos actores y tres campos; esto documenta comportamiento, sin decidir la autorización de negocio.

CM-T25 y CM-T27 recorren la ruta legacy. El primero comprueba que el valor difiera del original; el segundo compara la máscara exacta. CM-T24 confirma el resultado del propietario y CM-T26 la ausencia de pedido para un UUID inexistente. Las dos XFAIL de CM-T22 se refieren solo al correo bajo P-ORDER-01. No establecen seis incumplimientos de campo, enumeración viable de UUID o datos reales comprometidos.

### D Conservación e integridad

Los manifiestos identifican commits, versiones de herramientas, casos y hashes. El paquete de evidencia conserva los tres ZIP históricos y los resultados locales, con checksums. Los directorios de XML/JSON de máquina se excluyen solo de los formateadores de espacios finales y EOF para preservar sus bytes; su integridad se comprueba mediante hashes y estructura. El código, el manuscrito y el resto de documentación siguen bajo las reglas de calidad aplicables. Un hash conservado ayuda a verificar bytes disponibles; no los reconstruye si el archivo desaparece.

## VI Hallazgos y recomendaciones

El catálogo reúne catorce observaciones sustantivas. Su clasificación distingue controles positivos, caracterizaciones y brechas de decisión o documentación. Cada recomendación incluye una forma de comprobarla. No se asignó CVSS, no se estimó una probabilidad empírica y los trece dictámenes formales de riesgo permanecen NO_DETERMINADO. Las prioridades de investigación del primer avance conservan su función de selección del estudio.

### A2-H01 Vías de extracción de credenciales

La cabecera específica tiene precedencia; Authorization admite JWT/Bearer y rechaza prefijos incompletos o ajenos en los casos seleccionados. La extracción no autentica por sí sola y no demuestra consistencia con un proxy. Las unidades nuevas verifican bordes de formato, no tráfico HTTP externo.

La recomendación es documentar cabeceras admitidas y normalización del borde; conservar casos de cabecera ausente, incompleta y precedencia. Para verificarla: reproducir la matriz en el cliente y proxy reales y comprobar que solo la credencial prevista llega al backend.

Trazabilidad: CM-T17, CM-U09; R01. Código: saleor/core/auth.py:8-16.

### A2-H02 Backoff y procedencia de IP

Existe retraso creciente con contadores IP/usuario y bordes deterministas; la función IP toma la primera cadena válida del encabezado antes del fallback remoto. La sintaxis de IP no prueba confianza del origen; ni los bordes de una función ni una caché simulada prueban resistencia distribuida o bloqueo malicioso de cuentas.

La recomendación es fijar la política de proxy/caché, documentar umbrales y aislar el origen confiable; conservar regresión de los bordes y probar concurrencia acotada cuando exista entorno. Para verificarla: registrar cabecera recibida tras el borde y contadores efectivos con identidades sintéticas; no usar volumen de fuerza bruta.

Trazabilidad: CM-T18, CM-T19, CM-U08, CM-U10; R02. Código: saleor/account/throttling.py:21-71,95-129; saleor/core/utils/__init__.py:57-71.

### A2-H03 Respuesta ante credenciales inválidas

Las dos variantes históricas de cuenta conocida con contraseña errónea y cuenta inexistente producen el mismo código de error y no emiten credenciales. No se midieron distribución de tiempos, códigos HTTP comparados, recuperación de contraseña o registro. Igual código no demuestra ausencia completa de enumeración.

La recomendación es mantener respuestas externas uniformes y revisar los demás canales; medir tiempos con un protocolo pequeño y controlado si se adopta el requisito completo. Para verificarla: comparar contenido y estado sin datos de cuenta y registrar tiempos bajo condiciones equivalentes, sin extrapolar una muestra mínima a equivalencia estadística.

Trazabilidad: CM-T09; R03. Código: saleor/graphql/tests/test_cybermarket_security_extended.py:90-114.

### A2-H04 Validación de tipo firma y vigencia JWT

La integración histórica rechaza access usado como refresh y alg none. Las unidades nuevas rechazan una firma HS256 alterada, exp pasado y nbf futuro con reloj fijo, tras comprobar el control de firma válida. Las unidades no cubren todas las ramas RS256, rotación de claves o receptores. No se transforma su PASS en certificación de gestión criptográfica.

La recomendación es conservar controles negativos por propiedad y añadir RS256/rotación cuando se amplíe el alcance, manteniendo separación entre autenticidad, tipo y receptor. Para verificarla: ejecutar contratos equivalentes en cada receptor previsto con claves efímeras y expectativas independientes; no registrar JWT completos.

Trazabilidad: CM-T10, CM-T21, CM-U01, CM-U02, CM-U03; R05, R08. Código: saleor/core/jwt_manager.py:183-200; saleor/graphql/account/mutations/authentication/refresh_token.py:76-90.

### A2-H05 Revocación de credenciales por usuario

La revocación cambia jwt_token_key; el caso histórico establece acceso válido antes y comprueba que access y refresh anteriores dejan de servir en las rutas seleccionadas. No se probó cada consumidor, proveedor de identidad o cierre de interfaz. La cadena de datos y consumidores importa más que encontrar un método llamado logout.

La recomendación es mantener una regresión de la secuencia válida-revocación-reuso y un inventario de consumidores que comprueban la clave. Para verificarla: reutilizar credenciales anteriores por las rutas identificadas y registrar ausencia de datos o de nueva emisión; incorporar un consumidor adicional solo si entra en alcance.

Trazabilidad: CM-T02; R07. Código: saleor/graphql/account/mutations/authentication/deactivate_all_user_tokens.py:13-27; saleor/core/auth_backend.py:124-156.

### A2-H06 CSRF según transporte del refresh

La cookie requiere csrfToken; la ruta por argumento explícito tiene un contrato distinto. La matriz histórica comprueba presencia/ausencia/error y la unidad nueva compara secretos iguales o distintos bajo máscaras válidas. No se probó origen en navegador, preflight CORS, almacenamiento del frontend ni todos los formatos malformados. El resultado es de la condición implementada.

La recomendación es documentar el modelo de cliente y mantener casos por transporte, sin presentar el argumento explícito como un bypass automático o el CSRF como defensa universal. Para verificarla: en C10, comparar peticiones del navegador con origen permitido/no permitido y preservar tokens solo en memoria.

Trazabilidad: CM-T03, CM-U04; R06. Código: saleor/graphql/account/mutations/authentication/refresh_token.py:60-145; saleor/graphql/account/mutations/authentication/utils.py:55-65.

### A2-H07 Cookies condicionadas por configuración

El middleware fija HttpOnly y usa Secure/SameSite según DEBUG. La caracterización histórica distingue ambos modos. El nombre refreshToken carece de los prefijos examinados en ASVS 3.3.1. El efecto de navegador/TLS no se evaluó. La nomenclatura y el canal del mismo valor requieren interpretación de cliente/aplicabilidad; no constituyen por sí solos un exploit.

La recomendación es fijar DEBUG=False en el despliegue objetivo, documentar TLS y política de cookies y evaluar compatibilidad de prefijos dentro del contrato de cliente. Para verificarla: inspeccionar Set-Cookie sobre HTTPS y almacenamiento/flujo real antes de adjudicar la condición completa.

Trazabilidad: CM-T14; R06. Código: saleor/core/middleware.py:18-40; saleor/core/jwt.py:23.

### A2-H08 Separación de acceso a usuarios y personal

Las pruebas históricas comparan me anónimo/autenticado y user con actor ajeno, anónimo y personal con permisos

diferenciados sobre clientes o staff. La muestra no representa todos los campos y combinaciones de permisos. Un error de autorización aislado no prueba ausencia de efectos o datos en otras rutas.

La recomendación es mantener una matriz de rol-recurso-campo y extenderla solo para los campos pertinentes; verificar datos además de códigos de error. Para verificarla: afirmar exactamente qué entidad/campo se devuelve o queda ausente para cada consumidor y permiso.

Trazabilidad: CM-T01, CM-T12, CM-T13; R10. Código: saleor/graphql/account/resolvers.py:76-119.

### A2-H09 Intersección de permisos delegados

Los tokens de acción delegada restringen permisos mediante intersección de usuario y aplicación; dos variantes históricas cubren solapamiento y conjuntos disjuntos. No se evaluó una app real, todo el ciclo de revocación o la política de cada servicio receptor. Intersección local no demuestra corrección de toda delegación.

La recomendación es documentar scopes y consumidores y conservar controles de intersección vacía/parcial; revisar cambios de permisos durante la vida del token. Para verificarla: emitir credenciales sintéticas para permisos conocidos y comparar el conjunto exacto, además del efecto al ejecutar una operación autorizada o denegada.

Trazabilidad: CM-T20; R13. Código: saleor/core/jwt.py:172-199.

### A2-H10 Semántica de pedidos UUID y legacy

Con UUID conocido, actores ajenos/anónimos obtienen campos sintéticos originales; la ruta legacy aplica ofuscación. Controles de propietario e ID ausente y comparación exacta caracterizan el resultado. Las unidades nuevas muestran dominio/primer carácter/longitud residuales y la precondición de formato del helper. No se demuestra enumeración de UUID, obtención desde storefront o fuga real. P-ORDER-01 sigue provisional; sus dos XFAIL de correo no son dos vulnerabilidades ni cubren por separado las calles.

La recomendación es definir si el UUID es una capacidad compartible, quién puede recibirlo y qué campos corresponden a cada audiencia; acordar información residual permitida y validar entradas del helper. Para verificarla: trazar el flujo legítimo de entrega del ID y repetir la matriz por actor/campo en un despliegue controlado con una política explícita, sin parchear el producto para aprobar una propuesta tácita.

Trazabilidad: CM-T05, CM-T06, CM-T07, CM-T22, CM-T23, CM-T24, CM-T25, CM-T26, CM-T27, CM-U05, CM-U06, CM-U07; R11. Código: saleor/graphql/order/types.py:2161-2222,2636-2665; saleor/core/anonymize.py:1-18.

### A2-H11 Límites configurables de consultas

Se registran validadores de costo, alias y mutaciones; los casos históricos rechazan dos elementos cuando el umbral se configura en uno. No se midió costo máximo general, profundidad exhaustiva, carga, estrés o capacidad distribuida. Un rechazo de dos operaciones no acredita disponibilidad global.

La recomendación es documentar límites efectivos y agregar valores bajo/en/sobre umbral para consultas pertinentes; separar ensayos funcionales de rendimiento. Para verificarla: comprobar el rechazo antes de ejecutar operaciones y la ausencia de efectos laterales; medir rendimiento solo bajo un protocolo autorizado distinto.

Trazabilidad: CM-T15, CM-T16; R12. Código: saleor/graphql/core/validators/__init__.py:26-49.

### A2-H12 Captura amplia y diagnóstico de errores

get_payload transforma excepciones JWT específicas; get_user captura Exception y convierte cualquier causa en ausencia de usuario. La inspección identifica una captura amplia, pero no demuestra una explotación. Puede reducir la precisión diagnóstica y ocultar una dependencia averiada.

La recomendación es acotar excepciones esperadas y diferenciar errores recuperables/internos en registros depurados, manteniendo respuestas externas prudentes. Para verificarla: introducir en una prueba aislada una excepción prevista y una inesperada y verificar respuesta/registro sin revelar datos ni credenciales.

Trazabilidad: S06; R08. Código: saleor/graphql/account/mutations/authentication/utils.py:19-58.

### A2-H13 Audiencia conservada frente a receptor validado

El claim aud se conserva en emisión/renovación. El decoder permite verify_aud opcional y lo desactiva por defecto al tratar tokens propios. Conservar el claim no valida una allowlist del receptor. La aplicabilidad depende de servicios, emisores y modelo de audiencia; no se demuestra aceptación indebida de un token de otro servicio.

La recomendación es definir receptores y públicos previstos y documentar cómo se valida o limita el uso del token; diseñar un negativo de audiencia ajena si corresponde. Para verificarla: presentar un token sintético válido para otro receptor y observar rechazo bajo un contrato de servicio explícito, sin asumirlo por un claim presente.

Trazabilidad: CM-T08, CM-T11; R08. Código: saleor/core/jwt_manager.py:183-200; saleor/graphql/account/mutations/authentication/refresh_token.py:138-145.

### A2-H14 Vida absoluta e inactividad de sesión

Se comprueban TTL de emisión de access/refresh, pero no se dispone de una política del caso que fije inactividad, vida absoluta y reautenticación ni de una prueba de esa sesión completa. Expirar un JWT y renovar otro no prueban que una sesión no pueda prolongarse más allá de un máximo de negocio. No se inventa que la configuración sea incorrecta sin ese criterio.

La recomendación es definir una política temporal justificada por el caso y distinguir caducidad de token, revocación e interacción del usuario; seleccionar una prueba con reloj

controlado. Para verificarla: recorrer una secuencia de renovaciones y comprobar el máximo absoluto/inactividad adoptados antes de afirmar conformidad.

Trazabilidad: CM-T08, CM-T11; R04. Código: saleor/settings.py:992-1000; saleor/graphql/account/mutations/authentication/refresh_token.py:138-145.

## VII Discusión y propuesta de tratamiento

### A Correspondencia con los objetivos

La caracterización inicial de actores, activos y amenazas se conserva y gana precisión con los componentes, dependencias y condiciones de ejecución identificados. El examen técnico cuenta con inspección aplicada, herramientas estáticas y controles positivos/negativos, con fuente y resultado separados. El objetivo de observaciones con recomendaciones dispone de catorce entradas y de un método concreto de verificación posterior. No se atribuyen correcciones del producto o mejoras de riesgo que no se aplicaron.

El principal resultado de integración de fuentes es la separación entre lo que hace el software y el criterio con el que se debe juzgar. En pedidos, una respuesta puede coincidir con una intención de acceso mediante capacidad o contrariar la política restrictiva propuesta para CyberMarket. En audiencia, un claim puede conservarse sin que exista una comprobación de receptor. En sesiones, un tiempo de token puede ser correcto y todavía faltar una política de vida absoluta. Estas diferencias justifican preguntas y recomendaciones distintas, en lugar de una etiqueta global de seguro o vulnerable.

### B Secuencia de tratamiento

Conviene resolver primero las decisiones que cambian la interpretación del comportamiento: audiencia legítima de pedidos y UUID, campos por rol, servicios receptores, tiempos de sesión y confianza del borde. Después se seleccionan casos que prueben esas decisiones en un entorno identificado. La configuración de cookies y la entrega del identificador requieren transporte real; una ampliación del decoder necesita controles criptográficos por algoritmo y receptor. Cada cambio funcional debe conservar un antes y después y su retest.

Los controles positivos ya observados deben mantenerse como regresiones. Las recomendaciones de diagnóstico pueden tratarse con pruebas de excepciones esperadas e inesperadas, manteniendo respuestas externas apropiadas y registros sin credenciales. Las propuestas no incluyen publicar el laboratorio, realizar fuerza bruta o afirmar beneficios económicos. Tampoco se presenta el ajuste de una fixture o un formatter como si hubiese cerrado una vulnerabilidad del producto.

### C Amenazas a la validez

La muestra intencional no representa estadísticamente a todo Saleor. El conocimiento del código influye en la selección de casos y puede dejar rutas sin observar. Las fixtures simplifican contraseñas, servicios y datos; por ello no se extrapolan costes o rendimiento de producción. La diferencia entre Python 3.12.14 local y 3.12.15 histórico se conserva, junto con versiones y archivos, para permitir repetir y contrastar el resultado.

La validez de constructo depende de medir la propiedad declarada. Contar IDs no mide ramas, y observar un error no acredita que no se devolvieran datos o se produjeran efectos. Comparar una máscara con el propio helper comparte su posible defecto; las expectativas literales nuevas aportan otra comprobación. Las relaciones ASVS/caso son hipótesis instrumentales y no equivalencias oficiales. El anexo C explicita la disposición de cada requisito para evitar que una matriz completa se interprete como cumplimiento completo.

La política provisional y la ausencia de C10 limitan el juicio sobre datos personales y configuración de navegador. El estudio no establece una fuga real, un mecanismo para obtener UUID de terceros o explotación en una tienda existente. Si el grupo adopta una política o aparece un despliegue controlado, los criterios y el dictamen deben actualizarse con evidencia nueva, manteniendo el historial.

## VIII Cierre del avance

La evaluación documenta prácticas de implementación y resultados verificables sobre una muestra de identidad y acceso. Se dispone de revisión estática aplicada, archivos históricos recuperados y unidades nuevas que amplían propiedades concretas. El catálogo de catorce observaciones permite proponer acciones sin atribuir vulnerabilidades o mitigaciones inexistentes. La relación entre versión, expectativa, resultado y límite es parte del resultado de investigación.

El siguiente trabajo técnico debe resolver criterios de negocio y completar la validación desplegada cuando exista el entorno apropiado. Para esta entrega, la revisión del grupo debe confirmar contenido, autoría y alcance antes de cargar el PDF. El registro de carga queda separado de la preparación del documento: disponer del archivo no demuestra que se haya entregado en el campus.

## Referencias


[1] Universidad Fidélitas, “Trabajo final de investigación: segundo avance”, consigna y rúbrica de CY-703 Seguridad de Software, s. f., pp. 1–3.

[2] Equipo CyberMarket CR, “Análisis del diseño seguro de autenticación y autorización en Saleor: aplicación al escenario CyberMarket CR”, primer avance presentado, CY-703 Seguridad de Software, Universidad Fidélitas, 2026.

[3] Arkthos, “saleor”, repositorio de código fuente, base 4cb1609a90eade14b6275a407bc7a00c35698090. Disponible: https://github.com/Arkthos/saleor/tree/4cb1609a90eade14b6275a407bc7a00c35698090

[4] Universidad Fidélitas, “Programa del curso Seguridad de Software de 14 semanas” y “Manual de Trabajo Final de investigación grupal”, materiales de CY-703, s. f.

[5] M. Souppaya, K. Scarfone y D. Dodson, Secure Software Development Framework SSDF Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities, NIST SP 800-218, feb. 2022. doi: 10.6028/NIST.SP.800-218. Disponible: https://csrc.nist.gov/pubs/sp/800/218/final

[6] N. R. Mead, E. D. Hough y T. R. Stehney II, Security Quality Requirements Engineering SQUARE Methodology, CMU/SEI-2005-TR-009, Software Engineering Institute, nov. 2005. Disponible: https://insights.sei.cmu.edu/documents/751/2005_005_001_14594.pdf

[7] OWASP Foundation, Application Security Verification Standard, versión 5.0.0, mayo 2025. Disponible: https://github.com/OWASP/ASVS/releases/tag/v5.0.0

[8] OWASP Foundation, Web Security Testing Guide, versión 4.2, 2020. Disponible: https://owasp.org/www-project-web-security-testing-guide/v42/

[9] Proyecto CyberMarket CR, “Evidencia C2–C9 y JUnit focal”, GitHub Actions, ejecución 39443927080, 20 oct. 2026, branch SHA c442099bc0ebee5194a6e58354944563e92e0d28. Disponible: https://github.com/Arkthos/saleor/actions/runs/39443927080. Archivos originales recuperados y verificados en evidencia/historica_2026-10-20.

[10] Proyecto CyberMarket CR, “Pruebas unitarias de propiedades de seguridad”, tests/test_cybermarket_security_units.py, commit 5c7e4233ba24412ed80e3cd9a76a2ee18e4990a9, 2 nov. 2026. Disponible: https://github.com/Arkthos/saleor/blob/5c7e4233ba24412ed80e3cd9a76a2ee18e4990a9/tests/test_cybermarket_security_units.py. Resultado local: evidencia/ejecucion_local/isolated.xml.

[11] J. H. Saltzer y M. D. Schroeder, “The protection of information in computer systems”, Proceedings of the IEEE, vol. 63, núm. 9, pp. 1278–1308, sep. 1975. doi: 10.1109/PROC.1975.9939.

[12] Universidad Fidélitas, “Codificación segura” y “Pruebas de software y calidad”, materiales docentes de semanas 7 y 8 de CY-703 Seguridad de Software, s. f.

## Anexo A Aplicación de los instrumentos

Los siete instrumentos mantienen la correspondencia del primer avance. Los productos citados se encuentran bajo security/ cybermarket/academic/avance2, salvo las rutas de tests indicadas. El repositorio conserva los CSV completos; las tablas siguientes sintetizan su uso.

| Instrumento | Aplicación y producto verificable |
|---|---|
| I01 Configuración | linea_base.md; linea_base_manifest.json; resultados_ci_manifest.json. Versiones, comandos, entorno y hashes. |
| I02 Arquitectura | Diagramas del primer avance y revision_codificacion.md. Componentes, rutas y fronteras. |
| I03 Riesgos | R01–R13 y relaciones en trazabilidad y casos. Dictamen NO_DETERMINADO. |
| I04 Requisitos | trazabilidad_avance2.csv. Disposición y límites de 23 requisitos ASVS. |
| I05 Pruebas | clasificacion_pruebas.csv; plan_pruebas.md; JUnit y resúmenes. Inventario, oráculos y ejecución. |
| I06 Observaciones | hallazgos_avance2.csv y .json. Catorce entradas con recomendación y verificación. |
| I07 Evidencia y citas | Manifiestos, SHA256SUMS, fuentes y referencias. Relación entre afirmación, versión y archivo. |

## Anexo B Inventario de pruebas

La tabla agrupa variantes por ID y clase de oráculo; no mide cobertura de líneas o ramas. “Contrato” es contrato local, “caracterización” describe la implementación y “política” es propuesta no aprobada. Fuente: JSON focal recuperado y clasificación técnica.

| ID | Propiedad o ruta examinada | Clase | Resultado |
|---|---|---|---|
| CM-T01 | me por identidad | Contrato | 1 PASS |
| CM-T02 | Revocación de access y refresh | Contrato | 1 PASS |
| CM-T03 | Refresh por cookie o argumento y CSRF | Contrato | 4 PASS |
| CM-T04 | Pedido por referencia externa | Contrato | 1 PASS |
| CM-T05 | UUID anónimo y campos | Caracterización | 1 PASS |
| CM-T06 | UUID por actor | Caracterización | 1 PASS |
| CM-T07 | Legacy y ofuscación | Contrato | 1 PASS |
| CM-T08 | Emisión audience y TTL | Contrato | 1 PASS |
| CM-T09 | Credenciales inválidas | Contrato | 2 PASS |
| CM-T10 | Access rechazado como refresh | Contrato | 1 PASS |
| CM-T11 | Audiencia conservada al renovar | Contrato | 1 PASS |
| CM-T12 | user y privilegios | Contrato | 1 PASS |
| CM-T13 | Personal y partición de permisos | Contrato | 1 PASS |
| CM-T14 | Flags de cookie por DEBUG | Caracterización | 2 PASS |
| CM-T15 | Límite de alias | Contrato | 1 PASS |
| CM-T16 | Límite de mutaciones | Contrato | 1 PASS |
| CM-T17 | Precedencia de cabeceras | Caracterización | 3 PASS |
| CM-T18 | Selección de IP | Caracterización | 3 PASS |

| ID | Propiedad o ruta examinada | Clase | Resultado |
|---|---|---|---|
| CM-T19 | Bordes de backoff | Contrato | 6 PASS |
| CM-T20 | Intersección delegada de permisos | Contrato | 2 PASS |
| CM-T21 | JWT sin firma alg none | Contrato | 1 PASS |
| CM-T22 | Correo bajo P-ORDER-01 | Política | 2 XFAIL |
| CM-T23 | UUID por actor ajeno y campo | Caracterización | 6 PASS |
| CM-T24 | UUID y control propietario | Caracterización | 3 PASS |
| CM-T25 | Legacy distinto del original | Caracterización | 6 PASS |
| CM-T26 | UUID inexistente | Caracterización | 2 PASS |
| CM-T27 | Legacy y máscara exacta | Caracterización | 6 PASS |

**Unidades nuevas**

Todas las variantes de esta tabla aprobaron en la ejecución local aislada. Las doce invocaciones del validador se registran aparte y no amplían el inventario de controles de producto. Fuente: isolated.xml y tests/test_cybermarket_security_units.py.

| ID | Propiedad y oráculo | Variantes PASS |
|---|---|---|
| CM-U01 | Firma HS256 válida y alterada; excepción exacta | 1 |
| CM-U02 | exp pasado con reloj fijo | 1 |
| CM-U03 | nbf futuro con reloj fijo | 1 |
| CM-U04 | Máscaras CSRF de secretos iguales o diferentes | 3 |
| CM-U05 | Ofuscación de cadenas contra literales | 6 |
| CM-U06 | Ofuscación de correo contra literales | 4 |
| CM-U07 | Varias arrobas y precondición del helper | 1 |
| CM-U08 | Selección y fallback de IP | 4 |
| CM-U09 | Cabeceras incompletas o ajenas | 4 |
| CM-U10 | Bordes de función de backoff | 5 |

## Anexo C Disposición de requisitos ASVS

Estos son los 23 requisitos seleccionados, no el estándar completo. La disposición indica la parte abordada por el estudio. Se conserva NO_DETERMINADO como dictamen formal en todos los registros. Los IDs en la columna de casos transcriben la relación explícita del CSV histórico; un guion significa ausencia de esa relación, no ausencia absoluta de evidencia. Las relaciones analíticas posteriores y las fuentes exactas están en trazabilidad_avance2.csv.

| ASVS 5.0.0 | Área y criterio resumido | Casos históricos explícitos | Alcance y límite |
|---|---|---|---|
| 3.3.1 | Cookies. Atributo Secure y nomenclatura de cookie aplicable | T14 | Aplicable parcial. Flags y nombre observables; no hay validación HTTPS real. Evaluar requisito de prefijo y arquitectura cliente sin inferir vulnerabilidad. |
| 3.3.2 | Cookies. SameSite de acuerdo con finalidad y origen | T14 | Aplicable parcial. Se observa SameSite por DEBUG; falta política de cliente/origen y navegador. |
| 3.3.4 | Cookies. HttpOnly para cookies de sesión y medios de transporte | T14 | Aplicable parcial. Se comprueba HttpOnly; no se evalúa exhaustivamente el transporte alternativo del mismo valor. |
| 3.5.1 | CSRF. Validación de origen para funciones sensibles si no depende del preflight CORS | T03 | Aplicable parcial. CSRF por cookie comprobado históricamente; unidades nuevas comparan secretos con máscaras válidas. Origen y CORS en navegador no verificados. Unidades: CM-U04. |
| 4.3.1 | GraphQL. Se han definido y evaluado límites de complejidad para queries seleccionadas | T15, T16 | Aplicable parcial. Dos umbrales configurados no son cobertura completa de costo/profundidad ni prueba de carga. |
| 6.1.1 | Autenticación. Política de defensa contra automatización documentada | — | Documental pendiente. El algoritmo existe; falta política de antiabuso y bloqueo malicioso del caso. |
| 6.1.3 | Autenticación. Vías de autenticación documentadas y distinguidas | T17 | Documental parcial. Precedencia y bordes de cabeceras comprobados. Falta inventario exhaustivo de canales y contrato del borde. Unidades: CM-U09. |
| 6.3.1 | Autenticación. Control ante intentos repetidos conforme a política | T18, T19 | Aplicable parcial. Selección de IP y bordes de backoff ampliados con unidades. No prueba resistencia distribuida, caché operativa o proxy confiable. Unidades: CM-U08, CM-U10. |
| 6.3.8 | Autenticación. No revelar cuentas válidas en fallos de autenticación | T09 | Aplicable parcial. Código de error común no cubre tiempos, registro o recuperación de contraseña. |
| 7.1.1 | Sesiones. Política de tiempo inactivo/absoluto documentada | — | Documental pendiente. TTL emitido no es política documentada de inactividad y vida absoluta. |
| 7.2.1 | Sesiones. Validación backend de token de sesión | — | Aplicable parcial. Validación backend observada en rutas; no revisión exhaustiva de todos los receptores. |
| 7.3.2 | Sesiones. Duración máxima absoluta y reautenticación según riesgo | — | Aplicable pendiente. Renovación y TTL no prueban reautenticación tras vida absoluta; mantener pendiente. |
| 7.4.1 | Sesiones. Revocación eficaz tras terminación | T02 | Aplicable parcial. Se reutilizan credenciales anteriores tras revocación en rutas elegidas; no todas las vías del producto. |
| 8.1.1 | Autorización. Decisiones de función y datos documentadas | — | Documental parcial. Matriz técnica parcial; política de campos/UUID sigue provisional. |
| 8.2.1 | Autorización. Permisos de operación comprobados en backend | T04, T20 | Aplicable parcial. Permisos en funciones elegidas; H10 exige revisión de la base y rutas completas, no solo consulta de pedido. |

| ASVS 5.0.0 | Área y criterio resumido | Casos históricos explícitos | Alcance y límite |
|---|---|---|---|
| 8.2.2 | Autorización. Control de acceso a objeto individual | T01, T05, T06, T07, T12, T13, T22, T23, T24, T25, T26, T27 | Aplicable parcial. Contratos y caracterización por actor conservados. Unidades de máscara amplían el helper; no adjudican la política provisional de acceso al objeto. Unidades: CM-U05, CM-U06, CM-U07. |
| 8.2.3 | Autorización. Control de acceso a campos protegidos | T01, T05, T06, T07, T13, T22, T23, T24, T25, T26, T27 | Aplicable parcial. Valores de campos y máscaras observados, con expectativas literales nuevas. Falta política de información residual y matriz exhaustiva de campos. Unidades: CM-U05, CM-U06, CM-U07. |
| 8.3.1 | Autorización. Decisión en servicio confiable y no en cliente | — | Aplicable parcial. Controles backend identificados; no se infiere cobertura de todos los servicios o clientes. |
| 9.1.1 | JWT. Validación firma antes de confiar en payload | — | Aplicable parcial. Se añadió rechazo de firma HS256 alterada con control positivo. No cubre todos los algoritmos, claves y receptores. Unidades: CM-U01. |
| 9.1.2 | JWT. Algoritmos permitidos conforme a contexto | T21 | Aplicable parcial. Un algoritmo no firmado rechazado; falta caracterización completa de algoritmos/contextos y confusión de claves. |
| 9.2.1 | JWT. Validación de vigencia temporal | T08 | Aplicable parcial. Emisión exp/iat histórica y rechazo de exp pasado/nbf futuro en unidades con reloj fijo. No equivale a una sesión completa ni a todos los receptores. Unidades: CM-U02, CM-U03. |
| 9.2.2 | JWT. Validación propósito/tipo de token | T03, T08, T10 | Aplicable parcial. Access no aceptado como refresh en ruta elegida; no todas las clases/receptores. |
| 9.2.3 | JWT. Audiencia por receptor/ servicio si aplica | T08, T11 | Aplicabilidad condicional. Se conserva aud; verify_ aud=False por defecto no es validación contra receptor esperado; decisión por servicio pendiente. |

## Anexo D Archivos y reproducción

El paquete de evidencia contiene los ZIP originales y los resultados locales. El código de producto y los tests públicos se consultan en el repositorio Arkthos/saleor, rama research/cybermarket-security-tests-v1. Los manifiestos distinguen el SHA del producto, el SHA de tests y el de documentación. La ejecución integrada nueva requiere PostgreSQL, caché y las condiciones del workflow; este documento no registra esa ejecución.

| Archivo o producto | Localización de evidencia |
|---|---|
| JUnit focal histórico y resumen | evidencia/historica_2026-10-20/cybermarket-junit.xml y cybermarket-summary.json |
| Archivo general histórico | ZIP original pytest-results_39443927003.zip; digest y conteo en archivo_verificado_manifest.json |
| Estático nuevo | evidencia/estatica/bandit.json, semgrep.json y run_manifest.json |
| Pruebas aisladas nuevas | evidencia/ejecucion_local/isolated.xml y SHA256SUMS |
| Catálogo y trazabilidad | evidencia/hallazgos_avance2.csv y trazabilidad_avance2.csv |
| Límite de despliegue | evidencia/decision_c10.md; siete casos sin ejecución |

El comando de verificación aislada ejecutado fue el siguiente. SECRET_KEY se configura con un valor sintético de laboratorio; nunca se conserva un secreto de una instalación real.

```
uv run pytest tests/test_cybermarket_security_units.py \
  security/cybermarket/test_validate_evidence.py \
  tests/test_cybermarket_evidence_validator.py \
  --noconftest -q -n 0 --tb=short \
  --junitxml=isolated.xml -o junit_family=legacy
```

El validador y las sumas permiten revisar coherencia y bytes; no adjudican cumplimiento de ASVS. Para ampliar la evaluación se deben conservar precondiciones, oráculo, versión, resultado bruto y límite interpretativo de cada caso.